En kort Introduktion til software sikkerhed.

Del 1 - Overblik og Introduktion

Af Martin Edwin Schjødt Nielsen

University College

Introduktion til serien ”En kort introduktion til software sikkerhed”

Dokumenterne i serien 'En kort introduktion til software sikkerhed' har til formål at give læseren en kort og pragmatisk introduktion til software sikkerhed. Fokus er primært rettet mod den overordnede tilgang og proces, og der lægges kun begrænset vægt på detaljer. Målet er at introducere de overordnede emner på et konceptuelt niveau, og indholdet er målrettet softwareudviklingsteams. Dette betyder, at emnerne ikke beskrives udtømmende i nogen af dokumenterne, men blot det, som udviklere og andre involverede i udviklingsprocessen bør være opmærksomme på

Serien ”En kort introduktion til software sikkerhed” er delt op i følgende 6 dele:

- Del 1 – Introduktion og overblik.
- Del 2 - System mål.
- Del 3 – Sikkerheds mål.
- Del 4 – Risikostyring og vurdering.
- Del 5 – Trusselsmodellering.
- Del 6 – Eksempel på en udviklings proces.

Indledende overblik

Ordet 'sikkerhed' er i sig selv ikke konkret eller sigende. Derfor er det vigtigt altid at definere, hvad der menes med begrebet sikkerhed i en given kontekst. I dette dokument tages der udgangspunkt i definitionen beskrevet i Figur 1.

> Et systems evne til at tilfredsstille et opstillet mål under interaktion med en fjendtlig aktør.

Figur 1 Definition af software sikkerhed

Systemmål kan defineres som brugstilfælde (use cases) for et system, og der tages typisk udgangspunkt i en eller flere aktører samt deres respektive mål med systeminteraktionen. Samlet set udgør alle brugstilfældene systemmålene. Derudover kan der opstilles misbrugstilfælde (abuse cases), som tager udgangspunkt i en eller flere fjendtlige aktørers ondsindede interaktion med systemet og deres mål. Samlet set kan disse betragtes som sikkerhedsmål, dvs. konkrete misbrugstilfælde af systemet, der resulterer i negative konsekvenser.

Sikkerhedsmål udledes fra systemmål. Som hjælp til denne proces kan CIA-modellen anvendes, hvilket beskrives i næste afsnit. Både system- og sikkerhedsmål bør beskrives på et højt abstraktionsniveau.

Opsummering:

- Systemmål kan udtrykkes som brugstilfælde for hver enkelt aktør som har en interaktion med systemet.
- Sikkerheds mål kan udtrykkes som en fjendtlig aktørs misbrugstilfælde af et eller flere brugstilfælde.
- Sikkerheds mål kan udledes ved at anvende CIA modellen på systemmålene.

CIA-modellen.

Al informationsteknologi (IT) anvendes til opbevaring og behandling af data. For eksempel bruges informationsteknologi til at bogføre beløb på en bankkonto, og sociale medieapplikationer som Instagram bruges til at opbevare billeder. Alt dette udgør data, der understøtter forretningsdriften, og disse kaldes **aktiver**

CIA-modellen præsenterer tre kategorier hvori aktiver kan kompromitteres, kategorierne vises i Figur 2

- Confidentiality – Fortrolighed
- Integrity – Integritet
- Availability – Tilgængelighed

Figur 2 CIA-modellen. På dansk kaldet FIT modellen

CIA-modellen kan anvendes til identificering af trusler mod aktiver og vurdering af, hvordan hver kategori kan udgøre en trussel mod et aktiv. Hvis fortroligheden på en bankkonto bliver brudt, vil uvedkommende kunne se saldoen på bankkontoen samt transaktioner ind og ud af kontoen. Hvis integriteten på bankkontoen krænkes, kan det betyde, at der uretmæssigt kan foretages hævninger eller indskud på kontoen. Dette indebærer, at uautoriserede ændringer kan foretages, og pålideligheden af dataene kan ikke længere opretholdes. Hvis tilgængeligheden bliver kompromitteret, vil det betyde, at bankkontoen ikke længere er tilgængelig, og derfor kan der ikke foretages ind- eller udbetalinger. Dette medfører, at det forretningsmæssige formål (systemmål) ikke længere kan opfyldes.

Opsummering:

- Aktiver er data som understøtter forretningsdriften.
- CIA-modellen præsenterer 3 kategorier hvori aktiver kan kompromitteres.